PORTFOLIO / MCP SECURITY

Secure MCP Integration Gateway

AI may choose a capability. It must not manufacture business authority.

77 **verified checks**

26 Java + 40 live HTTP/MCP + 11 release checks

Java 21 · MCP 2026-07-28 focused subset

Release candidate 1.0.0-rc.1

THE RISK

“Just expose the API as a tool”

is not a security model.

Who chooses the tenant?

Can the model inject a URL or SQL?

Can a token minted for API A reach API B?

Can an old approval authorize changed arguments?

What happens when a write is retried?

ARCHITECTURE

Separate the trust boundaries.

- identity-derived tenant
- scope + schema policy
- exact human approval
- quota + audit
- dedicated upstream credential

SMALL TOOL SURFACE

4 tools. Not 40.

orders.lookup	READ
inventory.check	READ
customer.documents.list	READ
orders.cancel	APPROVAL + WRITE

No arbitrary SQL · no dynamic URL · no tenant argument · no credential argument

EXACT APPROVAL BINDING

Approval ≠ generic permission

BOUND	tenant
BOUND	requester
BOUND	tool + immutable revision
BOUND	canonical argument fingerprint
BOUND	expiry + independent reviewer

Change one character → approval_binding_mismatch

ATTACK IT

Denials are part of the product.

PASS	wrong token audience
PASS	cross-tenant reads
PASS	self / cross-tenant approval
PASS	URL + SQL injection
PASS	MCP header/body mismatch
PASS	duplicate write retry
PASS	quota abuse
PASS	raw-data audit leakage

EVIDENCE

77 deterministic checks

26	40	11
Java	HTTP/MCP	Release

Native browser and official MCP v2 SDK acceptance remain separate explicit gates - not inflated into the passed count.

THE PRINCIPLE

AI can propose.
Policy decides authority.

Identity · tenant · destination · approval · idempotency · audit stay deterministic.

GitHub

github.com/AhadPorkar/secure-mcp-integration-gateway

Java 21 · MCP 2026-07-28 subset · Connector Hub sidecar

Release candidate 1.0.0-rc.1